

BALAJI

TECHNICAL REQUIREMENTS

Architecture, data, security, performance and delivery specification

Companion to: Balaji Electronic PRD v1.0

Status: POC technical baseline

Target: Responsive commerce PWA for Pune retail and wholesale

Principle: Fast core commerce; 3D and AI as progressive enhancements

ARCHITECTURE DECISION Use a modular monolith for the POC with strict domain boundaries and event interfaces. It is faster to ship and operate than premature microservices, while preserving clear extraction paths for search, inventory, media and AI.

Reference stack

Layer	Recommended baseline	Reason
Web	Next.js + TypeScript + React; server rendering; PWA	SEO, responsive delivery, shared UI and fast iteration
UI	Tailwind/CSS tokens + accessible headless primitives	Consistent system, glass fallbacks, keyboard support
Motion/3D	Motion library + Three.js/React Three Fiber; glTF	Controlled micro-motion and progressive 3D
API	Typed REST/OpenAPI or tRPC inside modular server	Contract clarity; simple POC deployment
Data	PostgreSQL; Redis-compatible cache/queue	Transactional commerce plus fast session/cart/search support
Search	Postgres FTS initially; Meilisearch/Typesense extraction path	500-SKU POC simplicity with scalable interface
Storage/CDN	S3-compatible object storage + image CDN	Licensed media, transformations and caching
Auth	Managed OTP/OIDC provider or audited auth library	Safer identity and step-up verification
Payments	India-capable gateway sandbox; signed webhooks	UPI/cards/net banking/links/EMI based on provider
AI	Retrieval layer + tool-gated LLM + policy filters	Grounded site help; controlled actions

1. System context and domains

Logical components

- Web/PWA client: SSR/streamed pages, responsive UI, offline shell, motion and 3D capability detection.
- Commerce API: catalog, pricing, inventory, customer, cart, promotion, checkout, orders, payments, quotes, bookmarks and sharing.
- Back office: catalog/media, price lists, inventory, content, orders, quotes, user verification and audit.
- Integration adapters: payment gateway, SMS/email, address/PIN validation, tax/invoice, courier/installation and future ERP/PIM.
- AI gateway: approved knowledge index, structured product retrieval, tool allowlist, safety/PII redaction, evaluation and trace logging.
- Observability: structured logs, traces, metrics, frontend vitals, error tracking, audit events and business analytics.

Domain boundaries

Domain	Owns	Must not trust
Identity & access	User, role, business profile, verification, sessions	Client-provided role or price tier
Catalog	Product/variant/category/attribute/media/document	Unlicensed external media
Pricing	Price lists, tax display, offers, tier calculation	Cached/client totals at checkout
Inventory	Location stock, availability, reservation, lead time	UI availability as fulfillment authority
Cart/checkout	Lines, adjustments, address, shipping, final quote	Product price embedded in request
Order/payment	Order state, payment intent/link, webhook ledger	Redirect result without signed webhook
Sharing	Short link, scope, filters, expiry/revocation	Protected price in public payload
AI help	Knowledge, conversations, citations, allowed tool calls	Model-generated commercial facts

2. Functional service requirements

Identity and authorization

- RBAC roles: guest, retail_customer, wholesale_pending, wholesale_verified, wholesale_suspended, catalog_editor, operations, support, finance_admin, super_admin.
- Authorization is enforced server-side per resource and field. Wholesale prices are never serialized for unauthorized clients.
- OTP endpoints are rate-limited by IP/device/identity; codes are hashed, short-lived and single-use.
- Secure httpOnly, SameSite cookies; CSRF defense; session rotation on authentication and privilege change.
- Wholesale approval records actor, timestamp, evidence reference, old/new state and reason.
- Admin accounts require MFA; high-risk price, refund and permission actions require re-authentication.

Catalog, search and pricing

- Product supports variants and category-specific attributes; canonical model/SKU uniqueness constraints.
- Search index document excludes nonpublic fields; protected wholesale index/price enrichment happens after authorization.
- Facets are schema-driven with unit normalization; numeric facets store canonical units.
- Price quote endpoint receives SKU/quantity/customer/location/coupon and returns signed calculation ID, line totals, taxes, discounts, expiry and explanations.
- Checkout recalculates all totals and rejects stale calculation IDs with a recoverable refresh response.
- Availability is location-aware and timestamped; “in stock” semantics are defined per fulfillment mode.

Order and payment state

Order state: draft → pending_payment → paid/authorized → confirmed → allocated → dispatched/out_for_delivery → delivered, with cancelled/return_requested/returned/refunded branches. Payment state is separate: created → pending → authorized → captured → failed/expired → refunded/partially_refunded. State transitions are explicit, validated and audited.

- Create idempotency key for checkout, order submission, payment creation and refund requests.
- Payment links use high-entropy opaque IDs, server-side amount/order binding, configurable expiry, revocation and one-time/limited-use rules.
- Webhooks require signature verification, timestamp tolerance, replay protection and durable event ledger.
- Redirect success pages poll/read server payment state; they do not mark orders paid.
- Store minimal payment metadata; never store raw PAN, CVV or UPI credentials.

3. Data model

Core entities

Entity	Key fields
User	id, mobile/email, status, locale, created_at
BusinessProfile	user_id, legal_name, GSTIN, addresses, verification_state, price_list_id
Product	id, slug, title, brand_id, category_id, status, tax_class
Variant	id, product_id, sku, model, option_values, dimensions, weight
MediaAsset	id, variant_id, type, url, poster_url, alt, rights_owner, license, focal_point
PriceList/Price	scope, variant_id, amount, currency, min_qty, starts_at, ends_at
Inventory	variant_id, location_id, on_hand, reserved, safety_stock, lead_time
Bookmark/List	owner/session, name, visibility; items, note, desired_qty
Cart	owner/session, mode, currency, expires_at; lines, calculation_id
Quote	business_id, version, lines, totals, expiry, approval_state
Order	customer/business, addresses, totals, state, calculation snapshot
Payment	order_id, provider_ref, state, amount, method; webhook events
ShareLink	token_hash, creator, scope, filter_json, expires_at, revoked_at
BotConversation	user/session, consent, messages, citations, tool traces, retention_until

Seed data contract

The companion CSV is suitable for ingestion after mapping. Production import must validate category, numeric price, stock, slug/SKU uniqueness, image rights, alt text and controlled animation treatment. Dummy images use descriptive placeholders, not third-party copyrighted binaries.

Retention and privacy

- Collect only data required for commerce, support, fraud prevention and legal obligations.
- Define retention by record type; isolate legal invoice retention from disposable bot/chat telemetry.
- Export/delete workflow covers profile, bookmarks and conversations subject to lawful retention.
- Analytics uses pseudonymous IDs; advertising/optional analytics waits for consent.
- Secrets and sensitive identifiers are encrypted at rest; logs redact OTP, tokens, addresses and payment payloads.

4. API and integration requirements

Representative endpoints

Method / path	Purpose	Controls
GET /api/catalog/products	Search/browse with facets and cursor	Public fields; cache; abuse limit
GET /api/catalog/products/:slug	PDP data and authorized price enrichment	Field-level authorization
POST /api/auth/otp/*	Request/verify OTP	Rate limit; hashed code; risk checks
POST /api/pricing/quote	Authoritative totals for quantities/context	Auth where needed; signed result
POST /api/carts	Create/recover guest or user cart	Signed session; idempotent merge
POST /api/checkout/orders	Create order from current calculation	Idempotency; server reprice
POST /api/payments/links	Create time-bound payment link	Authorized order owner/operator
POST /api/webhooks/payments/:provider	Receive payment event	Signature, replay guard, ledger
POST /api/share-links	Create scoped inventory/list URL	Scope policy; expiry; audit
POST /api/bot/messages	Grounded answer or approved tool proposal	Auth context; redaction; quotas

Contract standards

- Versioned OpenAPI contract; generated types; consistent error envelope with user-safe message and trace ID.
- Cursor pagination for catalog and operational lists; stable sort keys.
- ISO 8601 UTC timestamps; INR stored as integer paise; normalized units with display conversion.
- Correlation ID across browser, API, queue and integration; no sensitive data in IDs.
- Timeout, retry and circuit-breaker policies per adapter; only retry idempotent operations automatically.

Future integrations

Define adapters before selecting vendors: InventorySource, PriceSource, PaymentProvider, NotificationProvider, ShippingProvider, InstallationProvider, TaxInvoiceProvider and ProductMediaProvider. The POC ships fake/sandbox implementations behind the same interfaces.

5. Frontend and design-system requirements

Responsive baseline

- Mobile-first CSS; content breakpoints driven by layout rather than named devices. Validate at 360, 390, 768, 1024, 1280 and 1440 px.
- Server-render catalog/category/PDP content for SEO and fast first paint; hydrate interactive islands selectively.
- Shared tokens: color, type, spacing, radius, elevation, blur, motion duration/easing, z-index and container widths.
- Components cover navigation, mode switch, search, cards, price, quantity, tier table, badges, filters, compare tray, bookmark, cart, checkout, payment link, bot and QR.
- Every component has loading, empty, error, disabled, focus, hover, active and reduced-motion states.

Glass and 3D implementation

- Glass token includes translucent fill, border, shadow and backdrop blur; supports-color/blur fallback is opaque.
- Never place low-contrast text directly over changing imagery; add stable scrim or opaque panel.
- 3D assets: glTF/GLB, compressed geometry/textures, ≤2 MB initial poster+essential payload target, lazy-loaded viewer chunks.
- Viewer dynamically caps pixel ratio; pauses render loop when idle/offscreen; disposes GPU resources on unmount.
- A static image and complete textual specifications are mandatory fallbacks.

SEO and discoverability

- Unique titles/descriptions, canonical URLs, clean slugs, XML sitemap partitioned by type, robots controls.
- Product structured data only when price/availability/review data is truthful and current.
- Category content supports Pune intent naturally; no doorway pages or locality keyword stuffing.
- Share pages emit safe Open Graph metadata; protected wholesale content is noindex and access-controlled.

6. Non-functional requirements

Performance budgets

Metric / asset	Target	Test condition
LCP	≤ 2.5 s p75	Mid-tier mobile, representative 4G, production build
INP	≤ 200 ms p75	Real-user monitoring
CLS	≤ 0.10 p75	Fonts/media dimensions reserved
Initial JS	≤ 200 KB gzip route baseline	Exclude lazy 3D/bot chunks
Critical image	Responsive AVIF/WebP; ≤ 200 KB typical	Correct intrinsic dimensions and priority
3D payload	Poster first; viewer lazy; ≤ 5 MB per featured model goal	Capability-gated and cached
API browse p95	≤ 400 ms from application edge	Warm cache; representative filters
Checkout API p95	≤ 800 ms excluding provider redirect	Includes price/inventory validation

Availability and resilience

- POC target 99.5%; production SLO to be agreed by business criticality and support coverage.
- Graceful degradation: browsing continues if bot/3D/analytics fails; checkout blocks safely if price, inventory or payment authority is unavailable.
- Database backup with restore drills; explicit RPO/RTO before pilot.
- Queue failed events to dead-letter handling with alerting and replay tooling.
- Maintenance mode and feature flags for wholesale prices, payment methods, 3D, bot tools and campaigns.

Accessibility and localization

WCAG 2.2 AA is a release requirement. Use semantic HTML, complete keyboard support, accessible names/descriptions, predictable focus, announcements for async cart/save states and screen-reader-equivalent 3D data. Externalize all user-facing strings; support INR, Indian number grouping, Asia/Kolkata display and future English/Marathi/Hindi.

7. Security, compliance and abuse prevention

Security baseline

- Threat-model authentication, pricing authorization, payment links, webhook handling, admin tools, file upload, share links and bot tools.
- Follow current OWASP ASVS-aligned controls; dependency and container scanning in CI; patch SLA by severity.
- CSP with nonces/hashes, strict transport security, secure cookies, output encoding and validated redirects.
- Rate-limit search, OTP, login, QR creation, bot and checkout; add bot/fraud challenges only when risk signals justify friction.
- Validate uploads by type/signature, scan files, strip metadata where appropriate and serve from isolated origin.
- Encrypt secrets in managed secret store; rotate; separate dev/stage/prod accounts and data.
- Audit admin reads/changes for price, inventory, role, verification, order and refund.

India-specific review gates

Before production, obtain qualified legal/payment advice for applicable Indian privacy, consumer protection, e-commerce, GST invoicing, payment aggregation, refund and marketing-consent obligations. The system must support policy versioning, consent evidence, seller/business disclosures, grievance/support details, tax invoice data and transparent total pricing; exact obligations depend on Balaji's legal and operating model.

Bot security

- Treat retrieved content and user text as untrusted; defend against prompt injection and data exfiltration.
- Tools use server-side authorization and constrained schemas; model never receives reusable secrets.
- Financial/destructive actions require deterministic confirmation UI outside free-form chat.
- Evaluate factuality, citation correctness, refusal, privacy leakage, cross-role data exposure and unsafe tool calls before release.

8. Testing and delivery

Test pyramid

Level	Coverage
Unit	Pricing rules, tax rounding, tier selection, state machines, QR scope, permission predicates
Component	All states, keyboard behavior, contrast, responsive layout, reduced motion
Integration	Database boundaries, cache invalidation, search indexing, payment webhook, notifications
E2E	Guest retail, signed retail, wholesale pending/verified, bookmark merge, quote, payment failure/retry, QR
Contract	Provider adapters, OpenAPI compatibility, webhook fixtures
Performance	Core Web Vitals, load test search/cart/checkout, 3D memory and long-task budgets
Security	SAST/SCA, secret scan, DAST, authorization matrix, abuse/rate-limit and pre-pilot penetration test
AI evals	Grounding, citations, multilingual prompts, injection, privacy and tool confirmation

CI/CD gates

- Lint/typecheck/unit → build → component/all → integration → E2E smoke → dependency/security scan.
- Preview deployment for each change with seeded non-sensitive data.
- Database migrations are forward-compatible, reviewed, backed up and rollback/roll-forward tested.
- Production deploy uses staged rollout and feature flags; payment/webhook changes require sandbox evidence.
- Release dashboard shows errors, vitals, payment success, search zero-results and authorization anomalies.

Environments

Local → preview → staging → production. Staging uses sandbox providers and synthetic identities. Production data must never be copied into lower environments without approved anonymization. Seed scripts are deterministic and versioned.

Definition of done

- Acceptance criteria linked to automated or manual evidence.
- No critical/high security findings; no known wholesale price exposure path.
- Performance and accessibility budgets pass on agreed devices/browsers.
- Runbooks exist for payment outage, inventory mismatch, bot disablement, compromised share link and failed deployment.
- Operations can edit catalog/content, verify wholesale accounts, trace an order and revoke a share/payment link without engineering.

9. Build backlog and decisions

Suggested epics

Epic	Key deliverable	Dependency
Foundation	Repo, CI, environments, tokens, shell, observability	Hosting and identity choice
Catalog	Schema, seed import, PLP/PDP, media and admin	Taxonomy approval
Discovery	Search, facets, autocomplete, compare	Catalog completeness
Identity/B2B	OTP, roles, verification, protected tiers	Wholesale policy
Saved work	Bookmarks, lists, merge, alerts	Identity and catalog
Commerce	Cart, pricing, checkout, sandbox payment link	Payment/provider decisions
Share	Scoped short links and QR management	Public URL/domain
Site Guide	Knowledge ingestion, grounded answers, safe tools	Approved policies/content
Experience	Landing, motion, 3D featured assets, reduced modes	Brand and media rights
Hardening	A11y, performance, security, resilience, runbooks	End-to-end feature completion

Architecture decisions to record

- ADR-001 hosting/runtime and regions; ADR-002 auth provider and session model; ADR-003 catalog/PIM authority; ADR-004 search engine threshold; ADR-005 pricing authority; ADR-006 inventory reservation semantics; ADR-007 payment provider and link model; ADR-008 media rights/CDN; ADR-009 bot model, retention and tool policy; ADR-010 analytics/consent.

Required owner inputs

- Business/legal details, service PIN codes, operating hours and support contacts.
- Product feed, authorized brands, stock locations, GST/tax configuration and media rights.
- Retail/wholesale price policy, MOQ/slabs, verification, credit and quote approval.
- Delivery, installation, warranty, return, cancellation, refund and grievance policies.
- Payment methods/providers, analytics consent posture and launch languages.